Лекция №6. Методы идентификации пользователей и защита учетных записей, управление доступом

Современные подходы к обеспечению безопасности в цифровой среде

План занятия:

1. Основы идентификации и аутентификации
2. Факторы аутентификации и их применение
3. Многофакторная аутентификация (МФА)
4. Биометрические методы защиты
5. Управление доступом: основы
6. Современные угрозы и защита
7. Практические рекомендации

ГЛАВА 1

Почему идентификация и аутентификация важны?

41 000+

Инцидентов ИБ

зафиксировано в Казахстане в 2024 году

85%

Троянских атак

в финансовом секторе используют кражу учетных данных

2,6x

Рост угроз

по сравнению с 2023 годом

Данные: АО «ГТС», Лаборатория Касперского (2024)

Основные понятия: идентификация, аутентификация, авторизация

Идентификация

Определение пользователя по уникальному идентификатору (логин, ID, электронная почта)

Аутентификация

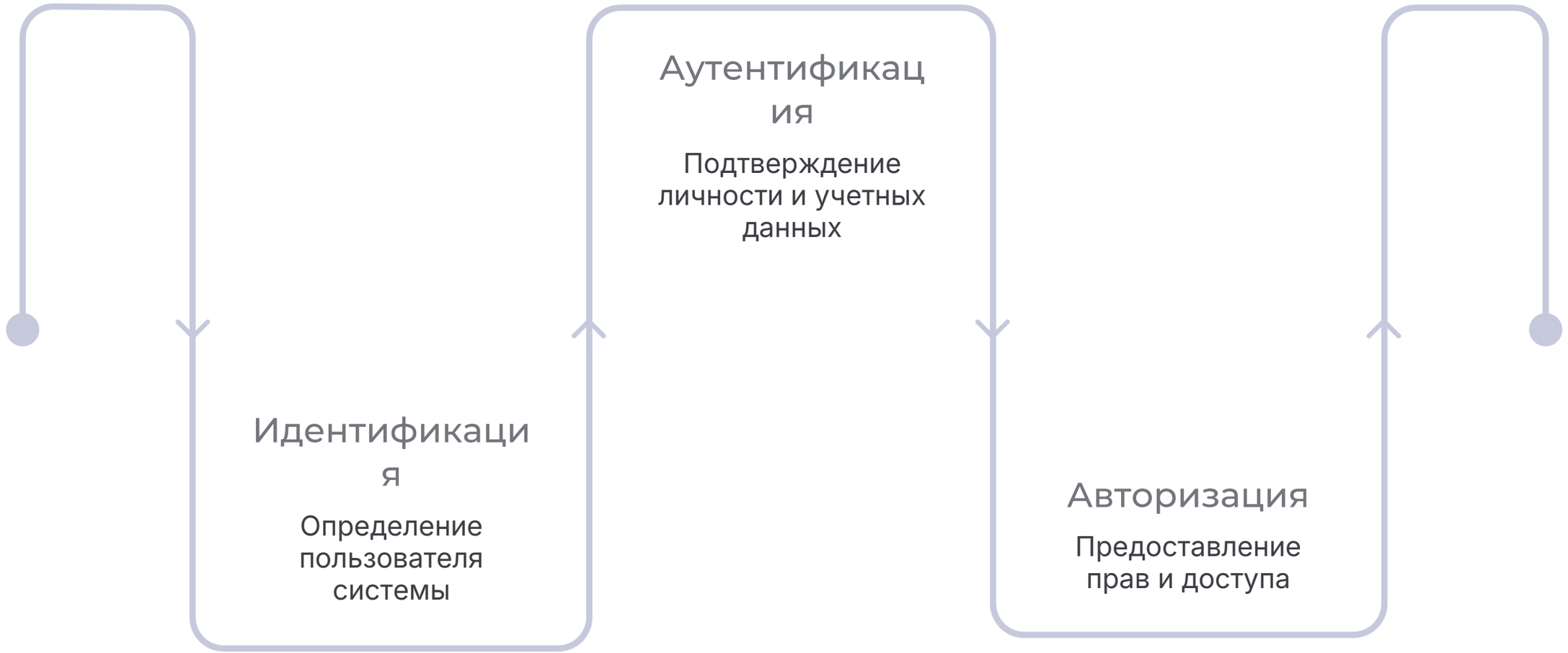
Подтверждение личности пользователя с помощью различных методов (пароль, биометрия, токены)

Авторизация

Предоставление прав доступа к ресурсам после успешной аутентификации

https://portswigger.net/web-security/authentication#what-is-the-difference-between-authentication-and-authorization

Цепочка безопасности доступа



Каждый этап этой цепочки критически важен для обеспечения комплексной защиты информационных систем и предотвращения несанкционированного доступа к конфиденциальным данным.

ГОСТ в Казахстане: новые уровни доверия аутентификации

Национальные стандарты ГОСТ устанавливают строгие требования к системам идентификации и аутентификации. Они определяют различные уровни доверия — от базового до усиленного — в зависимости от критичности защищаемых данных и систем.

Внедрение этих стандартов обеспечивает единый подход к безопасности во всех секторах экономики и государственных структурах Казахстана.

Ключевые факторы аутентификации

Что вы знаете

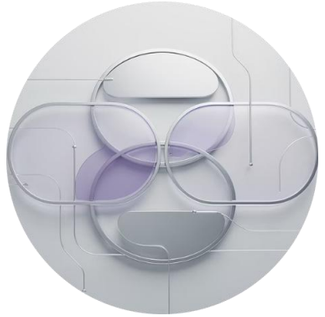
Пароль, PIN-код, секретный вопрос

Что у вас есть

Смартфон, токен, смарт-карта, USB-ключ

Чем вы являетесь

Биометрия: отпечаток пальца, лицо, голос, радужка глаза



Что вы делаете

Поведенческая биометрия, анализ паттернов использования

Пароли: классика с большими рисками

- Простые пароли легко взломать методом перебора или социальной инженерии
- Пользователи часто используют одинаковые пароли для разных сервисов
- Записанные пароли становятся уязвимостью
- Одноразовые пароли (OTP) и временные коды значительно снижают риски компрометации

Восстановление пароля: скрытая уязвимость

Функция "Забыл пароль?" есть на каждом сайте — но именно она часто становится самым слабым звеном в системе аутентификации.
Задание; https://portswigger.net/web-security/authentication/other-mechanisms/lab-password-reset-broken-logic

Типичные уязвимости при восстановлении пароля

Секретные вопросы

"Имя первого питомца?" — ответы легко угадать или найти в соцсетях.

Сброс через email

Если почта взломана — злоумышленник получает доступ ко всем аккаунтам.

Предсказуемые ссылки сброса

Токены с коротким сроком действия или слабой энтропией.

Утечка информации

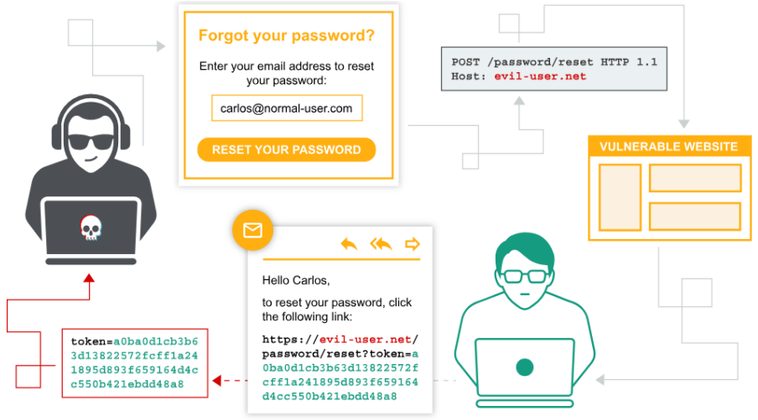
Сайт сообщает "такой email не зарегистрирован" — помогает перебирать аккаунты.

SMS-восстановление

Уязвимо к SIM-swapping атакам (перевыпуск SIM-карты мошенниками).

Отсутствие ограничений

Нет лимита на количество запросов сброса — возможен брутфорс.



Как защитить процесс восстановления пароля?

Реальный пример: SIM-swapping

Злоумышленник убеждает оператора связи перевыпустить SIM-карту жертвы, перехватывает SMS с кодом восстановления и получает полный доступ к аккаунту. Именно так были взломаны аккаунты ряда знаменитостей в Twitter в 2020 году.

Рекомендации по усилению безопасности https://portswigger.net/web-security/authentication/s

Токены с высокой энтропией

Использовать временные токены минимум 128 бит для сброса пароля.

Ограниченный срок действия

Ссылка для восстановления должна быть активна не более 15-30 минут.

Не раскрывать данные

Не сообщать, зарегистрирован ли email в системе, чтобы избежать перебора аккаунтов.

Уведомления пользователю

Отправлять оповещение о каждом запросе сброса пароля на все привязанные контакты.

МФА при восстановлении

Требовать дополнительный фактор аутентификации (например, SMS-код) при смене пароля.

Отказ от секретных вопросов

Заменить их на более надёжные методы верификации, так как ответы легко угадать или найти.

Многофакторная аутентификация (МФА)

Принцип работы

Требует предъявления двух и более факторов из разных категорий для подтверждения личности

Эффективность

Значительно повышает безопасность учетных записей, делая их практически неуязвимыми для большинства атак

Примеры

Пароль + аппаратный токен, пароль + SMS-код, пароль + биометрия

Схема многофакторной аутентификации

Комбинация различных факторов создает многоуровневую защиту, при которой компрометация одного фактора не приводит к получению несанкционированного доступа к системе.

Биометрические методы: преимущества и вызовы

Технологии

Отпечатки пальцев, распознавание лица, радужной оболочки глаза, геометрия ладони

Преимущества

Высокая точность идентификации и максимальное удобство для пользователя

Риски

Вопросы конфиденциальности и необходимость надежной защиты биометрических данных

Аппаратные токены и смарт-карты

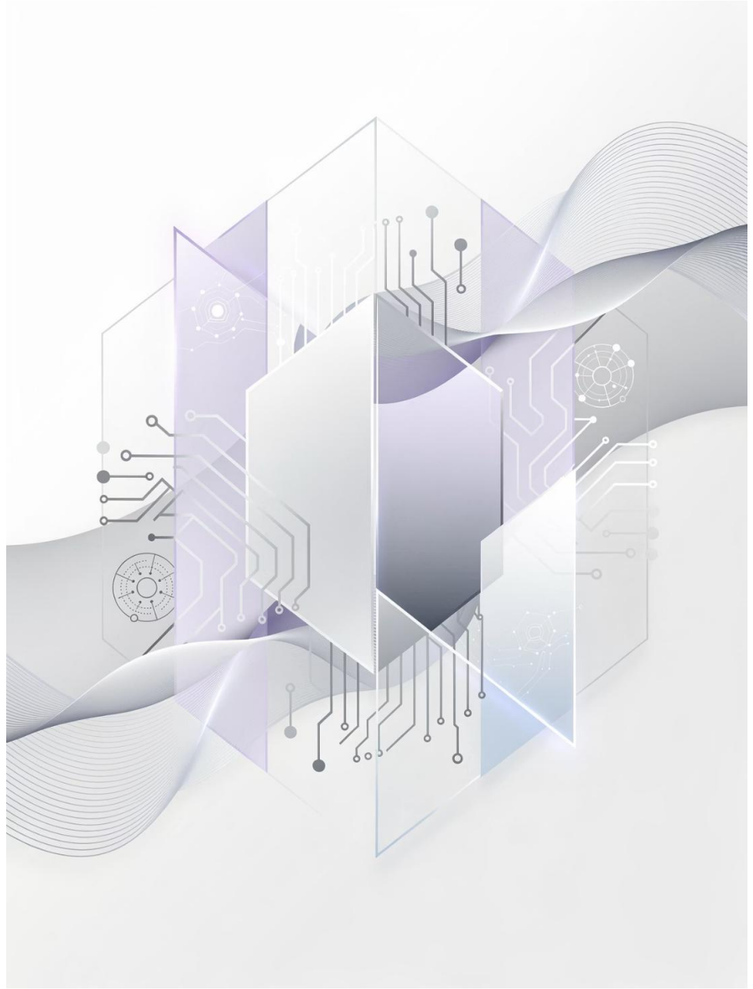
Принцип работы

Генерируют уникальные одноразовые коды для входа в систему на основе криптографических алгоритмов

Применение

Широко используются в банковской сфере и государственном секторе для защиты критически важных операций

банки активно внедряют аппаратные токены для онлайн-банкинга, обеспечивая дополнительный уровень защиты финансовых транзакций клиентов.



Поведенческая биометрия: новый уровень защиты

- Анализ скорости набора текста и ритма нажатий клавиш
- Отслеживание движения мыши и паттернов навигации
- Обнаружение аномалий в поведении пользователя
- Предотвращение мошенничества в режиме реального времени

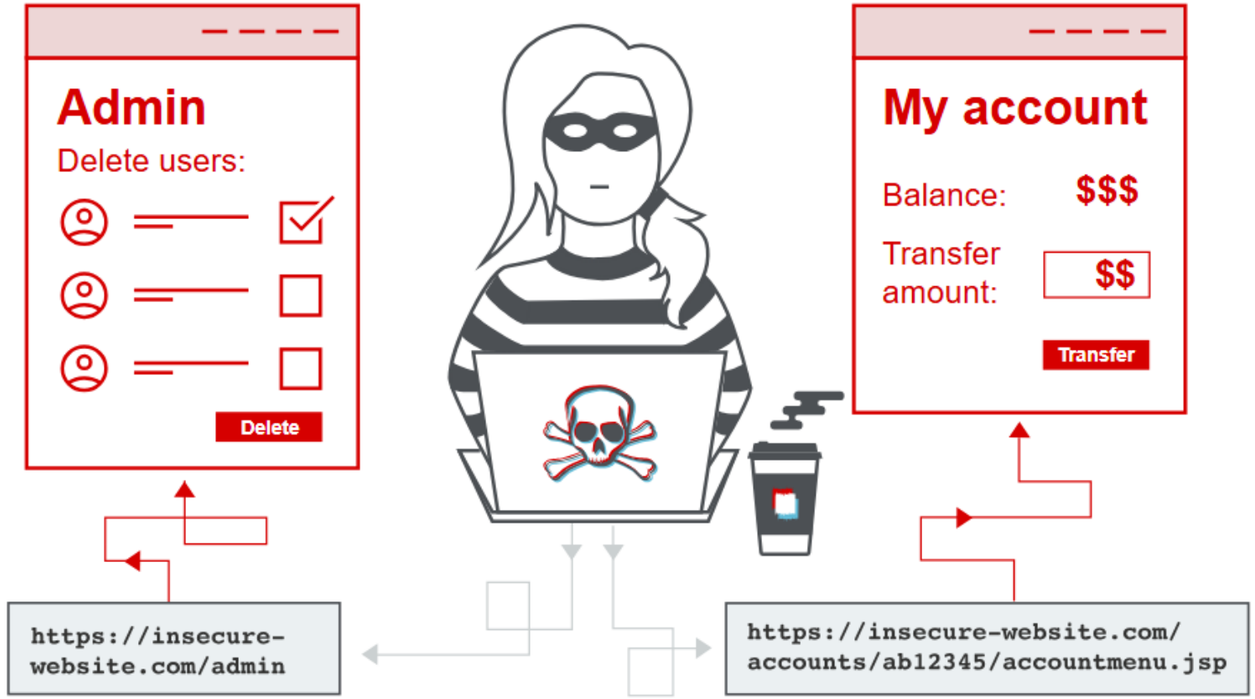
Технология активно внедряется в крупных финансовых организациях России и Казахстана для выявления подозрительной активности.

Что такое контроль доступа?

Контроль доступа — это применение ограничений к тому, кто или что имеет право выполнять действия или получать доступ к ресурсам. В контексте веб-приложений контроль доступа зависит от аутентификации и управления сессиями:

- **Аутентификация** подтверждает, что пользователь действительно является тем, за кого себя выдает.
- **Управление сессиями** позволяет определить, какие последующие HTTP-запросы отправляет тот же пользователь.
- **Контроль доступа** определяет, разрешено ли пользователю выполнять действие, которое он пытается совершить.

https://portswigger.net/web-security/access-control



ГЛАВА 1

Модели управления доступом: краткий обзор

DAC (Discretionary Access Control) - Дискреционная модель

Владелец ресурса сам решает, кому предоставить доступ. Гибкая, но менее безопасная. Подходит для малых компаний.

MAC (Mandatory Access Control) - Мандатная модель

Доступ строго по уровню секретности (конфиденциально, секретно, совершенно секретно). Используется в государственных структурах и банках.

RBAC (Role-Based Access Control) - Ролевая модель ⭐

Права назначаются в зависимости от должности/роли (администратор, редактор, читатель). Идеальна для среднего и крупного бизнеса.

ABAC (Attribute-Based Access Control) - Атрибутная модель

Доступ на основе различных атрибутов: время, местоположение, устройство. Самая гибкая, но и самая сложная в настройке.

💡 На практике часто используются гибридные модели, сочетающие преимущества разных подходов.

ГЛАВА 4

Управление доступом: что происходит после входа?

После успешной аутентификации система определяет, к каким ресурсам у пользователя есть разрешение.

Не все пользователи имеют одинаковый доступ ко всем функциям и данным.

По должности (ролевая модель)

Права зависят от вашей роли (например, **администратор**, **редактор**, **читатель**). Это самая популярная модель.

По уровню секретности

Доступ к информации строго по уровню конфиденциальности (используется в **госструктурах**).

Индивидуальные права

Каждому пользователю назначаются уникальные разрешения вручную (часто в **малых компаниях**).

RBAC: Ролевая модель - подробнее

Ролевая модель контроля доступа (RBAC) упрощает управление правами, назначая их не каждому сотруднику отдельно, а группам ролей. Это значительно повышает безопасность и удобство.

Основные компоненты:

- Пользователи (сотрудники, которые работают в системе)
- Роли (например, "Бухгалтер", "Менеджер", "Разработчик")
- Разрешения (конкретные действия: читать, изменять, удалять данные)
- Ресурсы (файлы, базы данных, функции приложений)

RBAC: Схема работы на примере

Рассмотрим, как ролевая модель контроля доступа (RBAC) работает в реальной ситуации.

Шаг 1: Принятие сотрудника

Иван Петров принят на должность **Бухгалтер**.

Шаг 2: Назначение роли

Системе назначается роль **"Бухгалтер"**.

Шаг 3: Права роли

- Доступ к финансовой системе
- Доступ к документообороту
- Доступ к электронной почте
- Доступ к корпоративному порталу

Шаг 4: Автоматический доступ

Иван автоматически получает все необходимые права.

Преимущества RBAC

Ролевая модель контроля доступа (RBAC) предлагает ряд ключевых преимуществ, которые делают ее идеальным выбором для большинства организаций.

Простота управления

Добавили нового сотрудника — назначили роль — готово! Не нужно настраивать каждое право отдельно.

Экономия времени

Изменили права для роли — изменения применились ко всем пользователям с этой ролью автоматически.

Меньше ошибок

Автоматизация снижает риск случайно дать лишние права или забыть дать нужные.

Прозрачность

Легко понять, кто и к чему имеет доступ. Удобно для проверок и аудита.

Правило 80/20

Ролевая модель покрывает 80% базовых потребностей. Остальные 20% можно запросить отдельно при необходимости.

Как создается ролевая модель?

Создание эффективной ролевой модели доступа — это поэтапный процесс, который требует внимательного анализа и согласования.

01

Анализ должностей и функций

Изучаем, какие задачи выполняют сотрудники разных должностей в организации.

02

Определение необходимых прав

Выясняем, какие конкретные действия и доступ к ресурсам нужны для каждой должностной функции.

03

Создание ролей

Объединяем определенные права в логические группы (роли), например, "Бухгалтер", "Менеджер по продажам", "Разработчик".

04

Тестирование и валидация

Проверяем, что созданные роли работают правильно и обеспечивают необходимый, но не избыточный доступ.

05

Согласование и утверждение

Руководители подтверждают, что ролевая модель соответствует реальным бизнес-процессам и потребностям безопасности.

06

Регулярное обновление

Модель пересматривается и корректируется при изменении бизнес-процессов, структуры компании или появлении новых систем.

💡 **Важно:** Ролевая модель — это живой организм, который нужно постоянно обновлять!

ГЛАВА 4

RBAC в реальной жизни: примеры

Ролевая модель контроля доступа (RBAC) применяется повсеместно, от образовательных учреждений до финансовых организаций.

Пример 1: Университет

Студент

Доступ к расписанию, оценкам, электронной библиотеке.

Преподаватель

Просмотр расписания, выставление оценок, создание заданий.

Администратор

Управление учетными записями, настройками системы, курсами.

Пример 2: Интернет-магазин

Покупатель

Просмотр товаров, оформление заказов, отслеживание доставки.

Менеджер

Обработка заказов, общение с клиентами, изменение статусов заказа.

Администратор

Управление каталогом товаров, ценами, акциями, учетными записями пользователей.

Пример 3: Банк

Кассир

Прием и выдача наличных, проведение базовых транзакций.

Контролер

Проверка и аудит операций, осуществляемых кассирами.

Менеджер

Открытие и закрытие счетов, консультирование клиентов, утверждение сложных операций.

💡 **Разделение обязанностей (SoD):** В банке кассир и контролер не могут быть одним и тем же человеком, чтобы предотвратить мошенничество и обеспечить внутренний контроль.

ГЛАВА 4

Какая модель используется на практике?

Понимание того, какие модели контроля доступа применяются в реальном мире, поможет вам выбрать оптимальное решение для вашей организации.

Статистика использования

Ролевая модель (RBAC) доминирует на рынке.

80-90%

RBAC (Ролевая)

Лидер среди всех моделей.

Гибридные модели (RBAC + ABAC) – растущий тренд для комплексных систем.

MAC (Мандатная) – специфична для госструктур, военных и банков.

DAC (Дискреционная) – используется лишь в очень малых компаниях (5-10 человек).

Почему RBAC побеждает?

Баланс простоты и безопасности

Обеспечивает адекватный уровень защиты без излишней сложности.

Легко масштабируется

Эффективно работает как в малых, так и в крупных организациях.

Понятна бизнесу

Проста в понимании и внедрении для нетехнических специалистов.

Готовые решения

Широкая поддержка в существующих системах (Active Directory, IAM).

ГЛАВА 5

Современные подходы и рекомендации

Современный тренд: "Умное управление"Лучшие практики сочетают RBAC для базовых прав и ABAC для дополнительных, динамических ограничений (например, по времени или местоположению доступа).

Рекомендации для разных организаций:

Малый бизнес (до 50 человек)

Простая RBAC или даже DAC для самых простых случаев

Средний и крупный бизнес

RBAC как основной подход для эффективного управления

Госструктуры, банки

MAC или RBAC с очень строгими, детальными ограничениями

IT-компании

RBAC + ABAC (гибридная модель) для максимальной гибкости и безопасности

ГОСТ Р 71753-2024

Управление учетными записями и правами доступа (IAM)

1

Стандартизация

ГОСТ регулирует автоматизированные системы управления учетными записями

2

Автоматизация

Создание, изменение и удаление учетных записей без участия человека

3

Контроль

Соответствие прав доступа корпоративной политике безопасности

Кибербезопасность в Казахстане: реальная статистика

Данные АО «Государственная техническая служба» и исследований 2024 года

1

Масштаб угроз (2024)

Более 41 000 инцидентов информационной безопасности зафиксировано за год — рост в 2,6 раза по сравнению с 2023 годом

2

Основные векторы атак

85% кибератак в финансовом секторе используют троянские программы. Казахстан занял 10-е место в мире по доле кибератак в финансовой сфере

3

Критическая важность МФА

Атака на Change Healthcare показала: отсутствие многофакторной аутентификации привело к масштабным сбоям и выкупу в $22 млн

Источники: АО «ГТС» (2024), Лаборатория Касперского, Positive Technologies

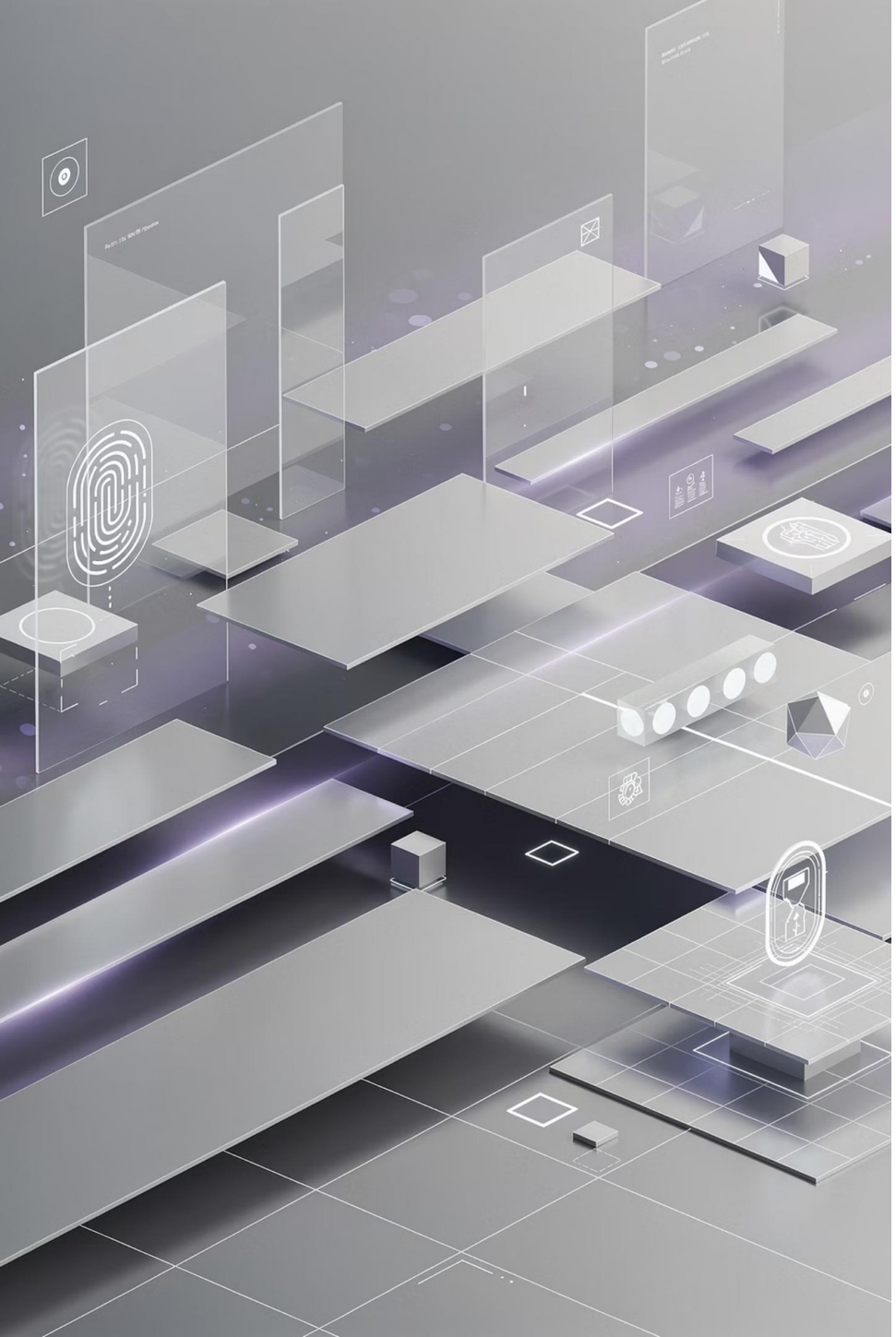
Современные угрозы и методы защиты

Актуальные угрозы

- Фишинг и целевые фишинговые атаки
- Кража учетных данных через утечки баз данных
- **взлом через credential stuffing** https://blog.kaspersky.kz/what-is-credential-stuffing/27709/
- Атаки с использованием украденных токенов
- Эксплуатация уязвимостей систем аутентификации

Методы защиты

- Адаптивная аутентификация с анализом контекста
- Непрерывный мониторинг активности пользователей
- Регулярное обновление систем безопасности
- Обучение сотрудников распознаванию угроз



Будущее идентификации: стандарты и инновации

01

Нормативная база

ГОСТы и международные стандарты задают единые рамки безопасности для всех участников рынка

02

Технологии

Развитие биометрии нового поколения и искусственного интеллекта для анализа поведения

03

Тренды

Рост популярности безпарольных технологий (passwordless) на основе криптографических ключей

Практические рекомендации по защите учетных записей

Используйте МФА

Включайте многофакторную аутентификацию везде, где это возможно

Обновляйте пароли

Регулярно меняйте пароли и избегайте их повторного использования

Контролируйте доступ

Отслеживайте права доступа и своевременно их отзывайте

Обучайте персонал

Проводите регулярное обучение основам кибербезопасности

Защита учетных записей — основа цифровой безопасности

ИИ в аутентификации: щит и меч

ИИ как защита

- Поведенческая биометрия: анализ паттернов набора текста, движений мыши
- Адаптивная аутентификация: динамическая оценка риска сессии
- Обнаружение аномалий: подозрительные входы по времени, стране, устройству
- Deepfake-детекция: распознавание поддельных лиц и голосов

ИИ как угроза

- Deepfake-атаки: генерация поддельного лица/голоса для обхода биометрии
- Credential stuffing: умный автоматизированный перебор паролей
- ИИ-фишинг: LLM генерирует убедительные письма для кражи данных
- Обход CAPTCHA: ИИ решает CAPTCHA лучше людей
- Клонирование голоса: обход голосовой аутентификации

ИИ — это одновременно щит и меч. Именно поэтому МФА и комплексный подход обязательны для обеспечения цифровой безопасности.

КЛЮЧЕВЫЕ ВЫВОДЫ

Итоги и ключевые выводы

Фундамент безопасности

Надежная идентификация и аутентификация — это основа защиты любой информационной системы

Комплексный подход

Современные методы защиты требуют сочетания технологий, процессов и автоматизации

Соответствие стандартам

ГОСТы 2024-2025 обеспечивают единые требования для защиты во всех отраслях

Задание и контрольные вопросы

Практическое задание

Спроектируйте ролевую модель доступа (RBAC) для выбранной организации (университет, больница или банк):

1. Определите не менее 3 ролей пользователей
2. Опишите права доступа для каждой роли
3. Укажите, какие методы аутентификации подходят для каждой роли
4. Объясните, как МФА усилит безопасность вашей модели

Чем отличается аутентификация от авторизации? Приведите пример из реальной жизни.

Почему одного пароля недостаточно для защиты учётной записи? Какие альтернативы существуют?

Что такое принцип наименьших привилегий и почему он важен в RBAC?

Как ИИ может одновременно усилить и ослабить систему аутентификации?

https://portswigger.net/web-security/all-topics https://portswigger.net/web-security/all-labs#authentication

https://portswigger.net/web-security/authentication/other-mechanisms/lab-password-reset-broken-logic